

Výstupy ŠVP

INF-19a Chráním digitální zařízení a digitální obsah před poškozením či zneužitím s vědomím změn v technologiích, které ovlivňují bezpečnost. (Informatika 4, 2/2 · z INF-19)

Učivo: bezpečnost počítačových zařízení a dat

Lehké úlohy procvičí druhy útoků, bezpečné návyky a jednoduché výpočty; střední kvantifikují sílu hesel a porovnávají ochrany; těžké spojují bezpečnost s kombinatorikou a pravděpodobností. Pojmy a vzorce máš v listu Must know. Vyber si, kolik úloh spočítáš; řešení si ukládej do svého portfolia.

Lehké ★☆☆

- Heslo má 8 malých písmen (26 možností na znak). Kolikrát víc možných hesel získáš, když (a) heslo prodloužíš o jedno malé písmeno, (b) ponecháš 8 znaků, ale povolíš i velká písmena? Které opatření pomůže víc?
- Přiřaď typ útoku k popisu: slovníkový útok, útok hrubou silou, keylogger, odposlech na veřejné Wi-Fi, odezíráání přes rameno. a) program zkouší postupně aaaa, aaab, aaac ...; b) někdo v tramvaji sleduje, jak zadáváš PIN; c) program v počítači zaznamenává stisknuté klávesy; d) zkouší se běžná slova a jejich obměny (heslo1, Heslo!); e) útočník v kavárně zachytává nešifrovaný provoz.
- Rozhodni, co je bezpečné a co riskantní, a zdůvodni: a) stejné heslo pro e-mail i sociální síť; b) správce hesel s jedním silným hlavním heslem; c) zapojit do počítače flash disk nalezený na chodbě; d) zapnuté automatické aktualizace; e) přihlášení do e-mailu na školním počítači bez odhlášení.
- Zálohuješ 200 GB fotek na externí disk rychlostí 100 MB/s. Jak dlouho záloha trvá? Proč nestačí mít zálohu jen na jednom disku doma?
- Přihlašovací stránka smyšlené banky je <https://www.bankaxy.cz/prihlaseni>. Které adresy jsou podezřelé a proč?
a) <https://bankaxy.cz/overeni-uctu.top/login>; b) <https://www.bankaxy.cz/ucty>; c) <https://www.bamkaxy.cz/prihlaseni>; d) <http://www.bankaxy.cz/prihlaseni>.
- Co z toho chrání před čím: antivir, firewall, aktualizace systému, záloha? a) otevření přílohy s virem; b) cizí počítač se snaží připojit k tvému počítači; c) útok přes známou chybu v prohlížeči; d) zašifrování dat ransomwarem.

Střední ★★☆☆

- Heslo z 8 malých písmen je uloženo jako otisk (hash). U rychlé hashovací funkce útočník vyzkouší 10^{11} hesel za sekundu, u pomalé (bcrypt) jen 10^4 . Jak dlouho nejvýš trvá vyzkoušet všechna hesla v obou případech? Proč servery používají pomalé funkce?
- Síla hesla v bitech je $\log_2$ počtu možností. Kolik bitů má frázové heslo ze 4 slov vylosovaných ze seznamu 2 048 slov? Kolik bitů má náhodné heslo z 8 znaků (94 možností)? Kolik slov je potřeba, aby fráze měla aspoň 60 bitů?
- Seřaď způsoby druhého ověření od nejslabšího po nejsilnější a zdůvodni: kód v SMS, hardwarový bezpečnostní klíč (USB/NFC), kód z ověřovací aplikace v telefonu.

10. Co program vypíše? Funkce odhaduje sílu hesla jako délka $\cdot \log_2$ (velikost použité abecedy). Proč odhad u třetího hesla přeceňuje jeho sílu? Jakou sílu má ve skutečnosti, pokud jsou to 4 náhodná slova ze seznamu 2 048 slov?

```
import math

def odhad_bitu(heslo):
    abeceda = 0
    if any(z.islower() for z in heslo):
        abeceda += 26
    if any(z.isupper() for z in heslo):
        abeceda += 26
    if any(z.isdigit() for z in heslo):
        abeceda += 10
    if any(not z.isalnum() for z in heslo):
        abeceda += 33
    return round(len(heslo) * math.log2(abeceda), 1)

print(odhad_bitu("kocka"))
print(odhad_bitu("Kocka2025"))
print(odhad_bitu("kocka-pes-strom-lampa"))
```

11. Co program vypíše? Proč mají dva uživatelé se stejným heslem bez „solí“ stejný otisk? K čemu je sůl (náhodný text přidaný k heslu před výpočtem otisku, uložený u uživatele)?

```
import hashlib

def otisk(sul, heslo):
    return hashlib.sha256((sul + heslo).encode()).hexdigest()[:8]

print(otisk("", "heslo123"), otisk("", "heslo123"))
print(otisk("x7Kq", "heslo123"), otisk("P2mz", "heslo123"))
```

12. Rozpoznej, kterou psychologickou páku sociotechnik používá: a) „Váš účet bude do hodiny zablokován!“; b) „Tady ředitel, pošlete mi hned seznam žáků s adresami.“; c) „Jen dnes zdarma pro prvních 10 lidí!“; d) „Poslal jsem vám dárek, jen potvrď převzetí přihlášením.“

Těžké ★★

13. Kolik je všech šestimístných PINů? Kolik jich zbude, když banka zakáže (a) opakování číslice v PINu, (b) nulu na začátku? O kolik procent se počet možností zmenší? Proč jsou podobná „bezpečnostní“ pravidla často kontraproduktivní?
14. Otisk (hash) má jen 32 bitů. Podle narozeninového paradoxu stačí asi $\sqrt{2 \cdot N \cdot \ln 2}$ náhodných vstupů, aby se s pravděpodobností 50 % našly dva se stejným otiskem (N = počet možných otisků). Kolik vstupů to je? Proč se používají otisky s 256 bity?
15. Firma má 200 zaměstnanců a každý na podvodný e-mail klikne s pravděpodobností 2 %, nezávisle na ostatních. Jaká je pravděpodobnost, že klikne aspoň jeden? Co z toho plyne pro obranu firmy?
16. Máš 100 GB dat, každý den se změní asi 2 GB. Varianta A: každý den úplná záloha. Varianta B: v neděli úplná záloha, ostatní dny jen přírůstková (změny od předchozí zálohy). Kolik místa zaberou zálohy za týden? Co je potřeba k obnově dat ve čtvrtek u varianty B?
17. Caesarova šifra posouvá písmena o pevný počet míst. Program zkouší všechny posuny zašifrovaného slova „dkrm“. Který posun dá smysluplné slovo? Proč je šifra s 25 klíči bezpečnostně bezcenná a jak se liší moderní šifry?

```
sifra = "dkrm"
for posun in range(1, 26):
    text = ""
    for z in sifra:
        text = text + chr((ord(z) - 97 - posun) % 26 + 97)
    print(posun, text)
```

18. Ověřovací aplikace generuje šestimístný kód platný 30 s. Útočník, který zná heslo, stihne v každém 30sekundovém okně 3 pokusy, pak ho server zpomalí. Jaká je pravděpodobnost, že se trefí během jednoho dne? Proč je druhý faktor účinný, i když má kód jen 6 číslic?

Výsledky ke kontrole

1. (a) 26^8 ; (b) $\frac{52^8}{26^8} = 2^8 = 256^8$; víc pomůže (b), ale dvě další písmena navíc ($26^2 = 676^8$) by pomohla ještě víc – délka hesla je nejsilnější zbraň
2. a) hrubá síla; b) odezírání přes rameno; c) keylogger (druh spywaru); d) slovníkový útok; e) odposlech na veřejné Wi-Fi (útok „muž uprostřed“)
3. a) riskantní – únik jednoho hesla otevře i druhý účet; b) bezpečné; c) riskantní – může obsahovat malware, který se spustí sám; d) bezpečné – opravují známé zranitelnosti; e) riskantní – další uživatel má přístup k účtu
4. $\frac{200\,000\text{ MB}}{100\text{ MB/s}} = 2000\text{ s} \doteq 33\text{ min}$; při požáru, krádeži nebo ransomwaru (je-li disk připojen) přijdeš o originál i zálohu – aspoň jedna kopie má být jinde (pravidlo 3-2-1)
5. a) podezřelá – skutečná doména je overeni-uctu.top, „bankaxy.cz“ je jen začátek názvu; b) v pořádku; c) podezřelá – překlep m místo n (napodobenina); d) nešifrované spojení (http bez s) – na přihlášení nepoužívat
6. a) antivir; b) firewall (filtruje síťová spojení); c) aktualizace (chybu opravují); d) záloha – data se obnoví (antivir může útok zastavit, ale ne vždy)
7. $26^8 \doteq 2,09 \cdot 10^{11}$ hesel; rychlá: asi 2,1 s; pomalá: $\doteq 2,1 \cdot 10^7\text{ s} \doteq 242\text{ dní}$; pro uživatele je 0,1 ms na přihlášení nepostřehnutelná, útočníka ale zpomalí desetmilionkrát
8. $4 \cdot \log_2 2048 = 4 \cdot 11 = 44\text{ bitů}$; $8 \cdot \log_2 94 \doteq 52,4\text{ bitu}$; aspoň 60 bitů: 6 slov (66 bitů, $5 \cdot 11 = 55$ nestačí)
9. SMS (útočník může přesměrovat číslo – výměna SIM, SMS lze odposlechnout) < aplikace (kód vzniká v telefonu, ale lze ho vylákat na falešném webu) < hardwarový klíč (ověří adresu webu, na podvodné stránce nefunguje)
10. 23.5 / 53.6 / 123.5; útočník nezkouší znaky, ale celá slova – fráze ze 4 slov má jen $4 \cdot 11 = 44$ bitů; odhad podle znaků platí jen pro náhodně vylosované znaky
11. b4240791 b4240791 / 4e553d17 5c02275f; stejný vstup dá vždy stejný otisk – útočník, který prolomí jeden otisk, zná heslo všech se stejným otiskem a může použít předem spočítané tabulky; se solí má každý jiný otisk a útočník musí lámat každé heslo zvlášť
12. a) naléhavost (nemáš čas přemýšlet); b) autorita; c) vzácnost (strach, že o něco přijdeš); d) reciprocita (cítíš povinnost oplatit laskavost); obrana: zpomal a ověř si požadavek jinou cestou
13. 10^6 ; (a) $10 \cdot 9 \cdot 8 \cdot 7 \cdot 6 \cdot 5 = 151\,200$ (o 84,9 % méně); (b) $9 \cdot 10^5$ (o 10 % méně); každé zákazové pravidlo zmenší počet možností, které musí útočník vyzkoušet
14. $N = 2^{32} \rightarrow$ asi 77 000 vstupů – to počítač vyzkouší za okamžik; u 256 bitů je potřeba asi $2^{128} \doteq 3,4 \cdot 10^{38}$ pokusů, což nikdo nezvládne
15. $1 - 0,98^{200} \doteq 0,982$, tj. asi 98 %; spoléhat jen na opatrnost lidí nestačí – je třeba i technická ochrana (filtr pošty, dvoufaktorové ověření, zálohy, omezená oprávnění)
16. A: $7 \cdot 100 = 700\text{ GB}$; B: $100 + 6 \cdot 2 = 112\text{ GB}$; obnova ve čtvrtek: nedělní úplná záloha a přírůstky z pondělí až čtvrtek (všechny musí být v pořádku)
17. posun 3 $\rightarrow$ ahoj (program vypíše 25 řádků, smysl dává jen ten); 25 klíčů vyzkouší člověk za minutu (útok hrubou silou); moderní šifry (AES) mají 2^{128} a víc klíčů
18. za den je 2 880 oken, v každém šance $\frac{3}{10^6}$;
 $1 - \left(1 - \frac{3}{10^6}\right)^{2880} \doteq 0,0086$, tj. asi 0,9 %; kód se stále mění a počet pokusů je omezený, uhodnutí je velmi nepravděpodobné – a server pokusy navíc ohlásí